Cyberbiosecurity ÇORUM 2026

DAY 2 · TUESDAY 3 NOVEMBER 2026 · 11:30–12:30

Institutional Cybersecurity Infrastructure

A practical case study



Prof. Dr. Ahmet Altun
Sivas Cumhuriyet University · Faculty of Medicine
Cyberbiosecurity Training Workshop · Hitit University, Çorum

A PRACTICAL CASE STUDY

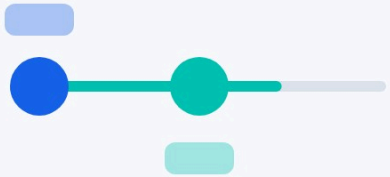
INSTITUTIONAL CYBERSECURITY INFRASTRUCTURE

CYBERBIOSECURITY TRAINING WORKSHOP · ÇORUM

PROF. DR. AHMET ALTUN

HEALTH SERVICE EXECUTIVE, IRELAND · 2021

Eight weeks from first email to ransomware



16 MAR 2021
Malicious email reaches a workstation

18 MAR
Opened; an Excel file downloads; foothold gained

31 MAR
Antivirus detects activity, but it is in monitor mode

7–13 MAY
Provider reports unhandled threats on 16+ systems

14 MAY, 04:00
Conti ransomware detonates; IT taken offline nationally

DWELL TIME

≈ 8 weeks

IMMEDIATE RESPONSE COST

€53 m

HSE figure to the Dáil Public Accounts Committee

ROOT FINDING (PWC)

Fragmented legacy IT, never designed to resist attack, and no single owner of cyber risk.



The signals were there. The structure to act on them was not.

Infrastructure is not only hardware. It is who owns the risk, who watches, and who may decide.

THREE LAYERS OF EVERY INSTITUTION

Technical, people, physical



01

Technical

Networks, instrument PCs, accounts, logs, backups

02

People

Staff, students, client technicians, vendor engineers

03

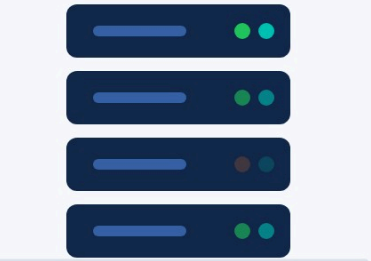
Physical

Doors, freezers, cabinets, sample stores, USB ports

REMEMBER A weakness in any one layer opens the other two. The people layer is usually the cheapest to attack.

THE CASE · A COMPOSITE, NOT ONE REAL INSTITUTION

A core lab that also serves industry



40+

instruments, many with a dedicated control PC

60

users: staff, students, visiting client technicians

12

external industry clients sending samples and data

8

vendors with some form of remote support access

WHY IT MATTERS

Client samples and data make this a supply-chain node: a breach here is a breach for twelve companies. In CSF terms, GV.SC is the centre of gravity.

TWO PHASES · TEN WEEKS

PHASE 1 · WEEKS 1–4

Assess

Inventory, network map, interviews, Current Profile

>

PHASE 2 · WEEKS 5–10

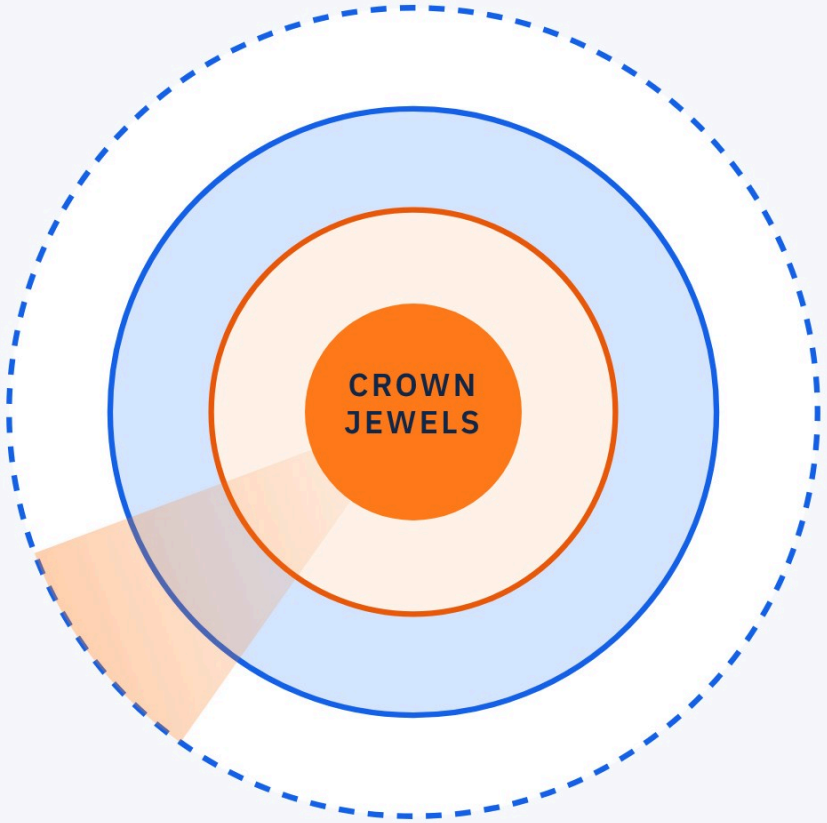
Build & train

Segmentation, identity, logging, backups, plans, people

Assessment first, then targeted investment. Buying tools before the inventory is the most common and most expensive mistake.

PHASE 1 · ID.AM, ID.RA

Start from what must never be lost



- **Perimeter**
  internet, email, vendors, cloud LIMS
- **Endpoints & accounts**
  PCs, laptops, shared logins
- **Lab devices & OT**
  instrument PCs, freezer and room monitors

THE CROWN JEWELS

- Client samples, results and contracts
- Instrument control and calibration data
- The cold chain: −80 °C storage and its alarms
- Unpublished research data and IP

PHASE 1 OUTPUT · TYPICAL FINDINGS

Eight findings, eight CSF subcategories



High	Instrument PCs on unsupported Windows versions, cannot be patched	PR.PS
High	One flat network: office PCs, Wi-Fi and instruments share a segment	PR.IR
High	Shared logins on instrument PCs; client technicians use staff accounts	PR.AA
High	Vendor remote-support tools installed and always on	GV.SC
Med	Results moved by USB stick between instruments and analysis PCs	PR.DS
Med	No central logging; instrument PC clocks drift by minutes	DE.CM
High	Backups exist; nobody has ever tested a restore	RC.RP
Med	No incident plan names the biosafety officer	RS.MA

Illustrative findings typical of shared research facilities; not from a single audit

THE PEOPLE LAYER



“Amateurs hack systems, professionals hack people.”

Bruce Schneier · security technologist

SOCIAL ENGINEERING, APPLIED TO THE CASE

Three phases, all in plain sight



1

Research

Staff names on the website, vendor names in public tender documents, instrument models in published papers

2

Develop

A friendly call from the “sequencer vendor’s service engineer” who knows the model and the lab head’s name

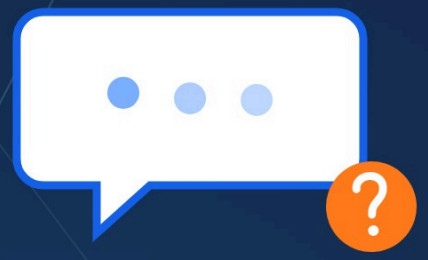
3

Exploit

“Please install this remote-support tool before Monday’s firmware update.”

DEFENCE Vendor access only through the jump host, requested by ticket, verified by a call-back to a known number.

THREE PRESSURES ATTACKERS USE



Ego

“You are the only one who really understands this system.”

Sympathy

“I will lose my job if this is not fixed today.”

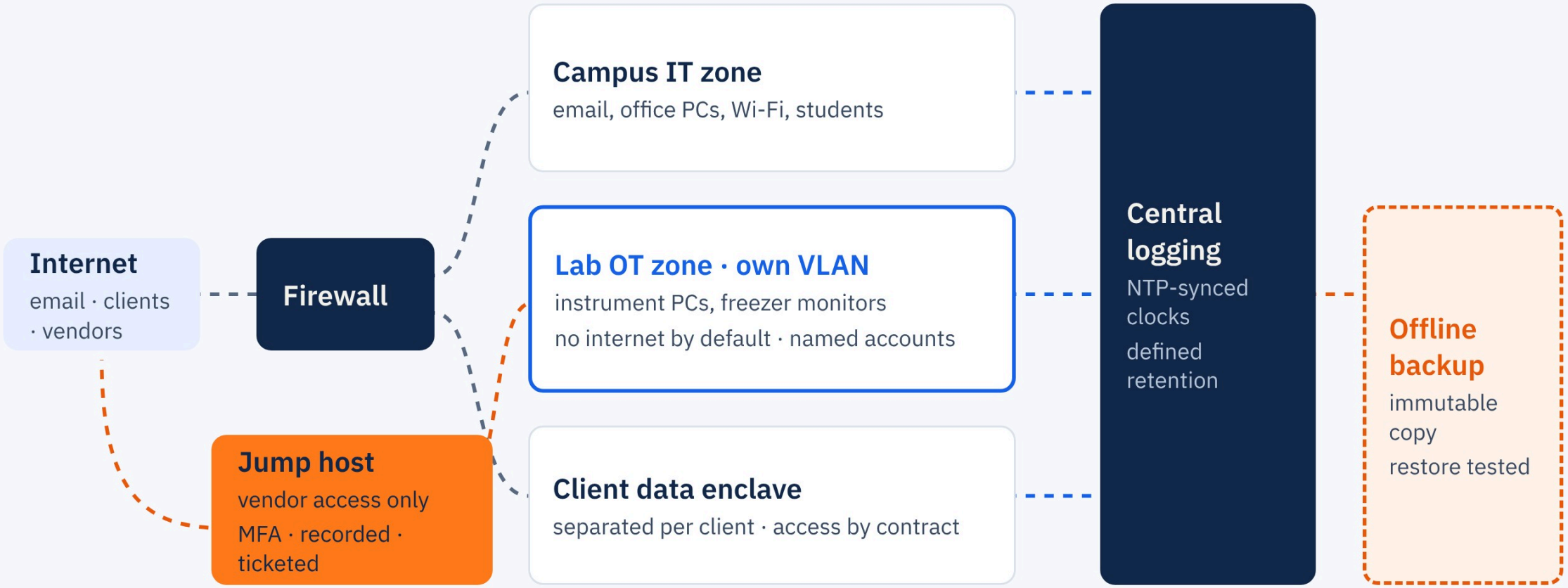
Intimidation

“This is the rector’s office / the regulator. Do it now and keep it quiet.”

Urgency plus secrecy is the signature. Train people to pause on both, and make reporting easy and blame-free.

PHASE 2 · TARGET ARCHITECTURE · PR.IR, PR.AA, DE.CM, RC.RP

Segment, gate, watch, keep a copy



IDENTITY LESSON · CHANGE HEALTHCARE · FEBRUARY 2024

192.7 million people

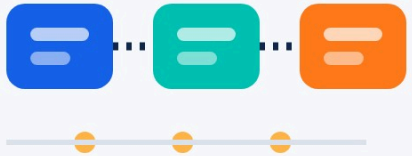
The attackers entered through a remote-access portal that **did not require multi-factor authentication**.

RULE **MFA on every remote path, and vendor paths first.**

Figure as reported to the U.S. HHS Office for Civil Rights, July 2025

SUPPLY-CHAIN LESSON · SYNNOVIS PATHOLOGY · JUNE 2024

When the lab is the supplier



One laboratory services provider. Two hospital trusts. Months of disruption.

10,146
outpatient appointments postponed

1,705
elective procedures postponed

2025
King’s College Hospital confirmed the attack was one contributing factor in a patient’s death

FOR A FACILITY

Turn it around: we are someone else’s Synnovis. Contracts with security and notification clauses, per-client separation, and a plan to tell every client within hours.

DE.CM · YOU CANNOT FIGHT WHAT YOU CANNOT SEE

Six log sources, three rules



- Firewall
- Identity / directory
- Jump host sessions
- Instrument PC events
- LIMS audit trail
- Freezer & room alarms

The freezer alarm is both a security signal and a biosafety signal.

Synchronise every clock

Without NTP, a timeline across instruments cannot be rebuilt.

Collect centrally

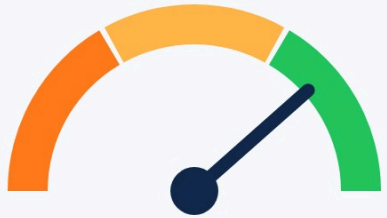
Logs on the compromised machine are the first thing an attacker deletes.

Decide retention in advance

The HSE intruder was inside for eight weeks. Keep at least that much.

DEFINITIONS AND THRESHOLDS

Name the level before you respond



Event

Observable occurrence
A failed login on the LIMS

Incident

Violates policy or threatens operations
Malware found on an instrument PC

Breach

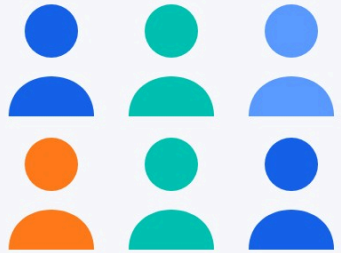
Confirmed loss of data
Client results copied out

Crisis

Threatens safety or the institution
Freezers or containment affected

COMMAND STRUCTURE · RS.MA, RS.CO

Who decides, who acts, who is told



Activity	Incident lead	IT / network	Biosafety officer	Lab head	Legal / DPO	Comms
Declare an incident	A	R	C	C	I	I
Isolate the lab network	A	R	C	C	I	I
Decide on samples and containment	C	C	A	R	I	I
Report under Law 7545 / KVKK	A	C	I	I	R	C
Inform clients and the public	A	I	C	C	C	R

R responsible · **A** accountable · **C** consulted · **I** informed. One A per row.

WHEN PRIORITIES COLLIDE

1 · Human safety
2 · Service continuity
3 · Data integrity
4 · Reputation

Even under pressure, preserve timestamps and chain of custody.



RC.RP · RECOVERY

The 3-2-1 rule



3

copies of the data

2

different media

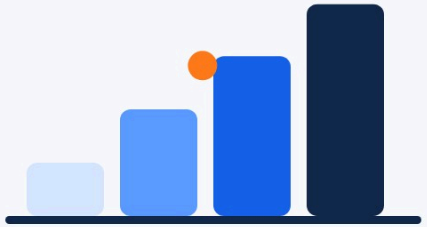
1

offline or immutable

A backup is a hypothesis. A tested restore is evidence.

SAME EVENT, THREE OUTCOMES

A maturity ladder for response



Suspicious PowerShell on an instrument PC, with an outbound connection.

LEVEL 1 · BASIC

Antivirus alert; manual isolation; sparse local logs

Panic and delay

LEVEL 2 · INTERMEDIATE

EDR alert; fast search for indicators; central logs

Controlled containment

LEVEL 3 · ADVANCED

Automated containment; threat hunting; segmented network

Neutralised in minutes

ASK THE ROOM

Where is your organisation on this ladder today? Level 2 is a realistic one-year target for most facilities.

START TOMORROW · A 30-DAY SPRINT

Four weeks, four deliverables



WEEK 1

Inventory & roles

Asset list, crown jewels, the incident lead and deputies

WEEK 2

Starter kit

A master plan and three playbooks: ransomware, vendor compromise, data leak

WEEK 3

Telemetry audit

Clocks synced, log sources connected, retention set

WEEK 4

Tabletop

A 60-minute exercise with IT, biosafety, lab heads and legal

Complexity is the enemy of execution. **Start with the basics, but start.**

METRICS THAT MATTER

You cannot manage what you do not measure



MTTD

Mean time to detect

MTTR

Mean time to respond

MFA %

Remote paths with MFA

Assets %

Devices on the inventory

Restore

Last successful test

Reports

Phishing reports by staff

Report them to leadership every quarter. Metrics turn security from a cost into a budget line.

THREE THINGS TO KEEP

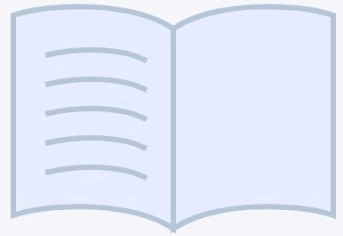
Inventory before investment.
MFA on every remote path.
Rehearse with biosafety.

13:30 · Laboratory cyberbiosecurity policies & SOPs · Prof. Dr. Gökçe Merey

14:30 · Hands-on: apply CSF 2.0

SOURCES

References and further reading



1. PwC. *Conti cyber attack on the HSE: independent post incident review*. Commissioned by the HSE Board; published 10 Dec 2021.
2. NHS England (London). Update on cyber incident clinical impact in south east London; 19 Sep 2024.
3. Infosecurity Magazine. Patient death linked to NHS cyber-attack (King's College Hospital statement); 26 Jun 2025.
4. CyberInsider. Change Healthcare revises breach impact to 192.7 million individuals (HHS OCR filing of 31 Jul 2025); 15 Aug 2025.
5. Nelson A, Rekhi S, Souppaya M, Scarfone K. *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. NIST SP 800-61r3; 2025. doi:10.6028/NIST.SP.800-61r3
6. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29; 2024. doi:10.6028/NIST.CSWP.29
7. Altun A. *Incident Response: Best Practices, Tools, and Resources*; and *Personnel-Related Vulnerabilities and Cybersecurity*. Workshop materials, 2026.
8. 7545 sayılı Siber Güvenlik Kanunu. Resmî Gazete 32846; 19 Mar 2025. · 6698 sayılı Kişisel Verilerin Korunması Kanunu.

QUESTIONS & DISCUSSION

Thank you.

Questions on building the infrastructure



Prof. Dr. Ahmet Altun
Sivas Cumhuriyet University · Faculty of Medicine
aaltun@cumhuriyet.edu.tr · ORCID 0000-0003-2056-8683